

Enci/ VENTAS

Manual de Roles y Permisos

Autorizacion Backend, Jerarquia de Roles, Accesos por Plataforma y Matriz de Permisos

Version 1.0
Julio 2026
Aplicacion de Automatizacion de Fuerza de Ventas

Ciente	Enci / Enci Ventas
Representante receptor	Max
Equipo desarrollador	Grupo PLM - Universidad Tecnologica Metropolitana (UTEM)
Lider de equipo	Joshua Flores
Integrantes	Falon Berrios, Carolaine Palacios y Eliseo Poblete
Repositorio oficial del MVP web	Chumajer14/Encipharm
Tipo de documento	Manual funcional y tecnico de autorizacion, roles, permisos y uso operativo

VENDEDOR Registros propios	SUPERVISOR Vision consolidada	ADMIN Gestion completa	BACKEND Autoridad final
--------------------------------------	---	----------------------------------	-----------------------------------

Naturaleza del documento
Este manual formaliza el modelo de acceso del sistema Enci Ventas, sus roles, permisos, restricciones por propiedad de datos y reglas de seguridad aplicadas desde backend. El frontend organiza la experiencia visual, pero no constituye fuente de autorizacion. La autorizacion definitiva vive en la API FastAPI, integrada con Firebase Auth, Firebase Admin y Firestore.

Tabla de Contenidos

1. Objetivo y alcance del manual
2. Principios del modelo de autorizacion
3. Roles operativos del sistema
4. Jerarquia backend de permisos
5. Acceso por plataforma: Web y App movil
6. Matriz general de permisos
7. Permisos por modulo funcional
8. Reglas de propiedad de datos
9. Estados de usuario y bloqueo de acceso
10. Gestion administrativa de usuarios
11. Casos de abuso y respuesta esperada
12. Checklist UAT de roles y permisos
13. Trazabilidad tecnica
14. Consideraciones de cierre

1. Objetivo y alcance del manual

El objetivo de este documento es establecer de forma clara que puede hacer cada tipo de usuario dentro de Enci Ventas, como se aplica la autorizacion, que restricciones existen sobre registros propios y ajenos, y que validaciones deben ejecutarse antes de considerar correcto el cierre funcional de roles y permisos.

El manual aplica al MVP web avanzado y a los servicios backend que lo soportan. Tambien considera el acceso por plataforma para app movil o PWA cuando el cliente indique el origen de la solicitud mediante el encabezado correspondiente. La app Flutter nativa parcialmente realizada se interpreta como componente adicional externo al repositorio, por lo que este documento se concentra en la autorizacion provista por la API y en los campos de acceso habilitados para web o movil.

Regla central

Ningun permiso se considera valido solo porque una pantalla o boton exista en la interfaz. Toda operacion sensible debe quedar protegida por backend mediante token Firebase, lectura de usuario en Firestore, verificacion de estado activo, validacion de rol y, cuando corresponda, validacion de propiedad del registro.

1.1 Alcance incluido

- Definicion de roles: vendedor, supervisor, admin y sin_acceso.
- Permisos sobre clientes, interacciones, oportunidades, propuestas, dashboards, usuarios, CSV, RAG, documentos RAG, competencia y consola tecnica.
- Reglas de visibilidad para registros propios y consolidados.
- Comportamiento esperado ante usuarios inactivos, sin rol habilitado o sin acceso por plataforma.
- Criterios de prueba UAT para comprobar que los permisos se cumplen en ambiente controlado.

1.2 Alcance excluido

- No define nuevas reglas comerciales fuera de las ya implementadas o aceptadas.
- No reemplaza el contrato, criterios de aceptacion ni acta de cierre.
- No documenta administracion interna de Firebase Console fuera de las acciones necesarias para operar usuarios del sistema.
- No garantiza permisos de sistemas externos no integrados, como ERP SAP, tiendas de aplicaciones o servicios de terceros no habilitados.

2. Principios del modelo de autorizacion

El sistema aplica un modelo de autorizacion defensivo. Cada solicitud protegida debe llegar al backend con un token Firebase valido. Luego la API consulta Firestore para obtener el usuario operativo, normalizar su rol, verificar su estado y decidir si la operacion procede.

El token Firebase confirma identidad, pero no basta para autorizar operaciones. La autorizacion depende del perfil almacenado en Firestore, de la jerarquia backend, del campo activo y del acceso por plataforma.

Principio	Aplicacion en Enci Ventas	Efecto operativo
Identidad	Firebase Auth entrega ID Token JWT al frontend.	Permite saber quien intenta operar el sistema.
Validacion backend	FastAPI valida Authorization: Bearer <token> con Firebase Admin.	Sin token valido, el endpoint responde 401.

Principio	Aplicacion en Enci Ventas	Efecto operativo
Perfil operativo	El backend consulta la coleccion users en Firestore.	El rol real no se toma desde el frontend.
Estado activo	Usuarios con activo=false son bloqueados.	El token puede ser valido, pero el acceso queda denegado.
Rol normalizado	Alias como administrador/admin se normalizan a roles internos.	Reduce errores por escritura o nomenclatura.
Plataforma	X-Enci-Client diferencia web y movil.	Permite bloquear webApp o appMovil por usuario.
Propiedad	vendedorUid u ownerUid restringen registros comerciales.	El vendedor no opera datos ajenos.

2.1 Flujo de autorizacion

```

Usuario -> Login Google -> Firebase Auth -> ID Token
Frontend -> Authorization: Bearer <firebase_id_token> -> FastAPI
FastAPI -> Firebase Admin -> valida token
FastAPI -> Firestore users/{uid} -> rol, activo, webApp, appMovil
FastAPI -> require_role(...) + propiedad de datos -> autoriza o rechaza

```

2.2 Respuestas esperadas

Condicion	Respuesta esperada	Interpretacion
Sin token, token mal formado o expirado	401 Unauthorized	La identidad no pudo validarse.
Usuario sin rol habilitado	403 Forbidden	Existe identidad, pero no acceso operativo.
Usuario inactivo	403 Forbidden	Cuenta bloqueada por configuracion administrativa.
Rol insuficiente	403 Forbidden	El usuario no cumple la jerarquia requerida.
Registro ajeno para vendedor	403 Forbidden	La propiedad del dato impide la accion.
Payload invalido o campos no permitidos	422 Unprocessable Entity	La estructura del request no cumple contrato.

3. Roles operativos del sistema

Los roles reflejan responsabilidades funcionales dentro del proceso comercial. La nomenclatura interna validada por backend corresponde a vendedor, supervisor, admin y sin_acceso.

Rol	Descripcion	Uso esperado	Limitacion principal
vendedor	Usuario comercial de terreno o ejecutivo asignado a clientes y oportunidades propias.	Opera clientes, interacciones, oportunidades, propuestas y Enci Chat dentro de su ambito.	No debe ver ni modificar registros comerciales de otros vendedores.
supervisor	Responsable de seguimiento, control y vision consolidada del equipo.	Consulta dashboards agregados, usuarios no sensibles, competencia y datos consolidados.	No reemplaza al admin para acciones sensibles de configuracion.
admin	Usuario con control completo del sistema y administracion operativa.	Gestiona usuarios, roles, estados, importaciones CSV, documentos RAG y configuracion critica.	Debe usarse solo para tareas administrativas y no como usuario comun.
sin_acceso	Estado inicial o restrictivo para usuarios autenticados aun no autorizados.	Permite registrar existencia de cuenta sin habilitar uso operativo.	No debe acceder a modulos protegidos.

3.1 Criterio de asignacion

La asignacion de rol debe responder a la funcion real del usuario dentro de Enci. No se recomienda entregar privilegios de admin para resolver problemas de visibilidad que puedan corregirse

mediante asignacion de vendedorUid, ownerUid, zona o reglas comerciales.

Control administrativo

Todo cambio de rol debe ejecutarse por un usuario admin y debe quedar asociado a una razon operativa. En ambientes productivos no debe existir cambio temporal de rol habilitado para usuarios comunes.

4. Jerarquia backend de permisos

La jerarquia se implementa desde backend mediante una regla de roles permitidos por nivel requerido. La regla es acumulativa hacia arriba: admin puede ejecutar acciones de supervisor y vendedor; supervisor puede ejecutar acciones de vendedor; vendedor solo puede ejecutar acciones habilitadas para vendedor.

Rol requerido por endpoint	Roles permitidos	Uso funcional
admin	admin	Administracion completa, usuarios, roles, CSV, documentos RAG y operaciones sensibles.
supervisor	admin, supervisor	Revision consolidada, dashboards de equipo, consulta de usuarios y competencia.
vendedor	admin, supervisor, vendedor	Operacion comercial base: clientes, oportunidades, interacciones, propuestas, dashboard individual y RAG chat.

4.1 Interpretacion de la jerarquia

- La jerarquia no elimina la validacion de propiedad de datos. Un endpoint puede aceptar rol vendedor, pero igualmente restringir registros por vendedorUid u ownerUid.
- Los permisos visuales del frontend no reemplazan la validacion de backend.
- Una cuenta autenticada puede existir en Firebase y en Firestore, pero seguir bloqueada si su rol es sin_acceso o si appMovil/webApp estan deshabilitados.

5. Acceso por plataforma: Web y App movil

El backend contempla control de acceso por plataforma para diferenciar solicitudes provenientes de la web y de clientes moviles. Esta regla permite habilitar o bloquear a un usuario segun el canal operativo aprobado.

Encabezado / valor	Plataforma interpretada	Campo Firestore evaluado	Efecto
X-Enci-Client: web	Web	webApp	Permite o bloquea uso de la aplicacion web.
X-Enci-Client: mobile	Movil	appMovil	Permite o bloquea uso desde app movil.
X-Enci-Client: movil	Movil	appMovil	Alias admitido para cliente movil.
X-Enci-Client: app	Movil	appMovil	Alias admitido para app movil.
X-Enci-Client: app_movil	Movil	appMovil	Alias admitido para app movil.
Sin encabezado	Web	webApp	Valor por defecto para navegacion web.

Relacion con Flutter

La app Flutter nativa parcialmente realizada puede consumir la API existente si envia token Firebase valido y se alinea con los contratos backend. Su ausencia en el monorepo no invalida el criterio de acceso movil; el backend mantiene el campo appMovil como control operativo por cuenta.

6. Matriz general de permisos

La siguiente matriz resume los permisos aceptados por rol para el alcance MVP. La descripción considera la regla funcional general; los endpoints concretos pueden aplicar validaciones adicionales de payload, propiedad, estado o ambiente.

Recurso	Vendedor	Supervisor	Admin
Login Google / sesion	Si, si esta activo y habilitado	Si, si esta activo y habilitado	Si, si esta activo y habilitado
Cientes propios	Crear, ver, editar y dar baja logica	Ver consolidado segun reglas	Gestion completa
Cientes ajenos	No	Ver segun alcance consolidado	Gestion completa
Interacciones	Crear y listar propias	Consultar consolidado	Consultar y administrar segun regla
Oportunidades	Crear, listar, editar y consultar propias	Consultar consolidado	Gestion completa
Propuestas	Crear, listar y actualizar propias	Lectura/revision segun regla	Gestion completa
Dashboard vendedor	Si	Si, por jerarquia	Si, por jerarquia
Dashboard supervisor	No	Si	Si
Usuarios	No	Listado y consulta no sensible	Gestion completa
CSV clientes	No	No	Importar
RAG chat	Si	Si	Si
RAG documentos	No	No	Cargar, listar y reindexar
Competencia	No operativo para vendedor	Consulta repositorio	Consulta por jerarquia
Swagger / docs	Uso controlado en ambientes no productivos	Uso controlado en ambientes no productivos	Uso controlado en ambientes no productivos

7. Permisos por modulo funcional

Modulo	Endpoints / vistas principales	Rol minimo	Regla funcional
Autenticacion	POST /auth/login, POST /auth/register, GET /me	Usuario autenticado	Valida token, sincroniza usuario y bloquea inactivos o sin acceso operativo.
Cientes	GET/POST /clientes, GET/PATCH/DELETE /clientes/{id}	vendedor	Vendedor queda limitado a clientes propios; admin gestiona completo.
Importacion CSV	POST /clientes/import-csv	admin	Carga masiva reservada a admin, con validacion de archivo y errores por fila.
Interacciones	GET/POST /interacciones	vendedor	Registra y consulta contactos comerciales vinculados a cliente visible.
Oportunidades	GET/POST/PATCH /oportunidades, GET detalle	vendedor	Pipeline comercial restringido por propiedad y visibilidad.
Propuestas	GET/POST/PATCH /propuestas	vendedor	Requiere cliente y oportunidad valida; calcula montos en backend.
Dashboard	GET /dashboard/vendedor, GET /dashboard/supervisor	vendedor / supervisor	Metricas propias para vendedor y consolidadas para supervisor/admin.
Usuarios	GET /users, PATCH /users/{uid}, role, status	supervisor / admin	Supervisor consulta; admin modifica datos, rol y estado.
RAG	POST /rag/chat, GET /rag/conversations	vendedor	Chat disponible para roles operativos con historial segun alcance.

Modulo	Endpoints / vistas principales	Rol minimo	Regla funcional
RAG documentos	POST upload, POST reindex, GET documents	admin	Administracion del corpus documental reservada a admin.
Competencia	GET /competencia/repository	supervisor	Repositorio competitivo visible para supervision y administracion.

7.1 Lectura funcional de los modulos

Los modulos comerciales comparten una regla comun: operar con identidad validada, aplicar rol minimo y proteger registros propios. La diferencia principal entre vendedor y supervisor/admin es el alcance de visibilidad y administracion, no la eliminacion de controles de seguridad.

8. Reglas de propiedad de datos

La propiedad de datos impide que un vendedor consulte o modifique informacion comercial asignada a otro usuario. La validacion se realiza en backend mediante campos como vendedorUid u ownerId. Esta restriccion es critica para proteger cartera, oportunidades y seguimiento comercial.

Entidad	Campo principal	Regla para vendedor	Regla para supervisor/admin
Cliente	vendedorUid / ownerId	Solo opera si coincide con su uid.	Puede consultar o gestionar segun permisos de rol.
Interaccion	vendedorUid y clienteld visible	Solo registra o lista interacciones propias o sobre cliente permitido.	Puede ver consolidado segun regla.
Oportunidad	vendedorUid y clienteld	Solo opera oportunidades propias o asociadas a cliente visible.	Puede consultar consolidado.
Propuesta	vendedorUid, clienteld y oportunidadId	Solo opera propuestas vinculadas a su ambito.	Puede consultar o gestionar segun regla.
Conversacion RAG	usuarioid	Lista su propio historial.	Puede consultar consolidado segun alcance implementado.

8.1 Criterio de rechazo

Cualquier intento de operar registros ajenos por manipulacion de identificadores, URL, payload o herramientas externas debe rechazarse antes de ejecutar la accion de negocio. La respuesta esperada es 403 cuando el problema es de permiso y 400/422 cuando el problema corresponde a formato, payload o contrato invalido.

Ejemplo de abuso esperado:

1. Vendedor A obtiene token valido.
2. Vendedor A intenta consultar /clientes/{id_cliente_de_vendedor_B}.
3. Backend obtiene el cliente, compara vendedorUid/ownerUid con uid del token.
4. Si no coincide, responde 403 y no entrega datos del cliente.

9. Estados de usuario y bloqueo de acceso

El acceso no depende solamente de la existencia de una cuenta Google. La cuenta debe estar registrada en Firestore, activa, con rol operativo y con plataforma habilitada.

Estado / campo	Valor	Resultado esperado
rol	sin_acceso	El usuario queda bloqueado para modulos protegidos. Debe ser habilitado por admin.
rol	vendedor	Acceso comercial propio y RAG chat.
rol	supervisor	Acceso consolidado, dashboard supervisor, usuarios no sensibles y competencia.

Estado / campo	Valor	Resultado esperado
rol	admin	Gestion completa y acciones sensibles.
activo	false	Bloqueo total aunque el token Firebase sea valido.
webApp	false	Bloquea acceso desde cliente web.
appMovil	false	Bloquea acceso desde cliente movil/app.
theme/language	dark/light, es/en/pt	Preferencias visuales y de idioma; no son fuente de autorizacion.

9.1 Alta inicial de usuario

Cuando un usuario se autentica por primera vez, el backend puede crear su documento en Firestore con rol sin_acceso y accesos de plataforma deshabilitados. Esta medida permite registrar la identidad sin abrir acceso automatico al sistema.

10. Gestion administrativa de usuarios

La gestion administrativa debe ejecutarse con cuenta admin. Las operaciones de supervisor se consideran de consulta y seguimiento, no de modificacion sensible.

Operacion	Rol autorizado	Criterio operativo	Riesgo si se usa mal
Listar usuarios	supervisor/admin	Permite revisar usuarios existentes, estado y datos operativos.	Exponer informacion de equipo a usuarios no autorizados.
Ver detalle usuario	supervisor/admin	Permite revisar rol, estado, zona y accesos.	Uso indebido para perfilar cuentas.
Cambiar rol	admin	Debe responder a funcion real del usuario.	Escalamiento excesivo de privilegios.
Activar/desactivar	admin	Permite bloquear cuentas sin eliminar identidad.	Bloqueos operativos no coordinados.
Editar datos operativos	admin	Permite ajustar nombre, cargo, rango, zona, webApp, appMovil.	Configuracion incorrecta de acceso por plataforma.
Preferencias propias	usuario autenticado	Cada usuario puede ajustar preferencias permitidas.	No debe permitir modificar rol ni estado.

10.1 Recomendaciones de gobierno de accesos

- Mantener la menor cantidad posible de cuentas admin.
- Asignar supervisor solo a usuarios con necesidad real de vision consolidada.
- Revisar periodicamente usuarios inactivos o cuentas sin uso.
- No usar cuentas compartidas para pruebas UAT ni operacion diaria.
- Documentar cambios de rol, especialmente en ambientes productivos o de cliente.

11. Casos de abuso y respuesta esperada

Los siguientes escenarios deben utilizarse como pruebas de control para confirmar que la autorizacion backend no depende del frontend.

Caso	Accion intentada	Resultado esperado	Severidad si falla
AB-01	Vendedor consulta cliente ajeno por URL directa.	403 sin datos del cliente.	Alta
AB-02	Vendedor crea interaccion sobre cliente ajeno.	403 o rechazo por propiedad.	Alta

Caso	Accion intentada	Resultado esperado	Severidad si falla
AB-03	Vendedor vincula propuesta a oportunidad ajena.	403 o rechazo por propiedad.	Alta
AB-04	Usuario inactivo usa token valido.	403 Usuario inactivo.	Alta
AB-05	Usuario sin_acceso intenta /clientes.	403 Usuario sin rol habilitado.	Alta
AB-06	Supervisor intenta importar CSV.	403 por falta de rol admin.	Media
AB-07	Vendedor intenta cargar documento RAG.	403 por falta de rol admin.	Media
AB-08	Usuario con webApp=false intenta operar desde web.	403 sin acceso a web app.	Media
AB-09	Usuario con appMovil=false intenta operar desde app movil.	403 sin acceso a app movil.	Media

Criterio de aceptacion

Los casos de abuso se consideran aprobados cuando el backend rechaza la accion incluso si la interfaz fue manipulada, la URL fue escrita manualmente o el request fue enviado desde una herramienta externa.

12. Checklist UAT de roles y permisos

Durante UAT se recomienda probar al menos una cuenta por rol. Las pruebas deben ejecutarse con usuarios reales o cuentas de prueba autorizadas por el cliente.

ID	Prueba	Rol	Resultado esperado
UAT-RP-01	Login Google y GET /me	vendedor	Retorna uid, email, rol vendedor y activo=true.
UAT-RP-02	Listado de clientes	vendedor	Lista solo clientes propios.
UAT-RP-03	Acceso a cliente ajeno	vendedor	403 sin exponer datos.
UAT-RP-04	Dashboard vendedor	vendedor	Metricas personales visibles.
UAT-RP-05	Dashboard supervisor	supervisor	Metricas consolidadas visibles.
UAT-RP-06	Intento de importar CSV	supervisor	403 por falta de rol admin.
UAT-RP-07	Gestion de usuarios	admin	Puede modificar rol y estado.
UAT-RP-08	Carga documento RAG	admin	Documento aceptado si cumple formato.
UAT-RP-09	Usuario inactivo	cualquier rol	403 al intentar usar endpoint protegido.
UAT-RP-10	Bloqueo appMovil/webApp	cualquier rol	Acceso rechazado segun plataforma.

12.1 Evidencia minima esperada

- Captura o registro de respuesta 200 para flujos autorizados.
- Captura o registro de respuesta 403/401/422 para flujos rechazados.
- Identificacion del usuario de prueba, rol utilizado y ambiente ejecutado.
- Fecha, responsable de ejecucion y observaciones en caso de defecto.

13. Trazabilidad tecnica

La definicion de roles y permisos se encuentra respaldada por el codigo backend y modelos de datos del repositorio oficial. Las referencias se incluyen para facilitar auditoria, mantenimiento y validacion tecnica posterior.

Elemento	Ruta tecnica	Uso en permisos
Validacion de usuario	Backend/app/core/auth.py	Valida Bearer token, consulta usuario Firestore, bloquea inactivos y aplica acceso por plataforma.
Jerarquia require_role	Backend/app/core/auth.py	Define roles permitidos para admin, supervisor y vendedor.
Modelo de usuario	Backend/app/models/user.py	Define rol, cargo, rango, zona, appMovil, webApp, theme, language y activo.
Usuarios API	Backend/app/api/users.py	Lista usuarios, obtiene detalle, actualiza perfil, rol y estado segun rol autorizado.
Cientes API	Backend/app/api/clientes.py	Aplica acceso vendedor a clientes propios y reserva import CSV para admin.
Comercial API	Backend/app/api/comercial.py	Aplica require_role vendedor para interacciones, oportunidades y propuestas.
Dashboard API	Backend/app/api/dashboard.py	Diferencia dashboard vendedor y supervisor.
RAG API	Backend/app/api/rag.py	Permite chat a roles operativos y documentos RAG solo a admin.
Firestore Rules	firestore.rules	Bloquea acceso directo cliente con deny-all.

13.1 Relacion con seguridad

Las reglas descritas forman parte del hardening defensivo del MVP. La seguridad no descansa en ocultar botones, sino en validar cada accion sensible desde backend. Este enfoque reduce riesgos BOLA, manipulacion de identificadores, acceso indebido por rol y uso de cuentas inactivas.

14. Consideraciones de cierre

Para efectos de cierre, el modulo de roles y permisos se considera aceptable cuando los flujos habilitados para cada rol funcionan en ambiente de validacion y los flujos prohibidos son rechazados por backend. Las observaciones posteriores deben clasificarse como bug critico, ajuste UAT o cambio de alcance segun corresponda.

Condicion	Criterio de cierre
Roles principales	vendedor, supervisor y admin operan segun matriz.
Usuario sin_acceso	No accede a modulos protegidos hasta habilitacion formal.
Usuario inactivo	Queda bloqueado aunque conserve token Firebase valido.
Propiedad de datos	Vendedor no ve ni modifica registros ajenos.
Acceso por plataforma	webApp y appMovil restringen canal correspondiente.
Admin	Puede gestionar usuarios, roles, estado, CSV y documentos RAG.
Supervisor	Puede consultar informacion consolidada sin ejecutar acciones admin sensibles.
Frontend	Puede ocultar acciones por rol, pero no se considera barrera de seguridad.

Cierre operativo

El control de permisos queda cerrado para Development si la API responde de acuerdo con la matriz, la jerarquia de roles y las reglas de propiedad. Cualquier ampliacion futura de permisos, nuevos perfiles, aprobaciones avanzadas o reglas por zona debe tratarse como mejora posterior o Fase 2.